

Student:

Devon Jacob

Email:

jacobd24@rowan.edu

Time on Task:

39 hours, 12 minutes

Progress:

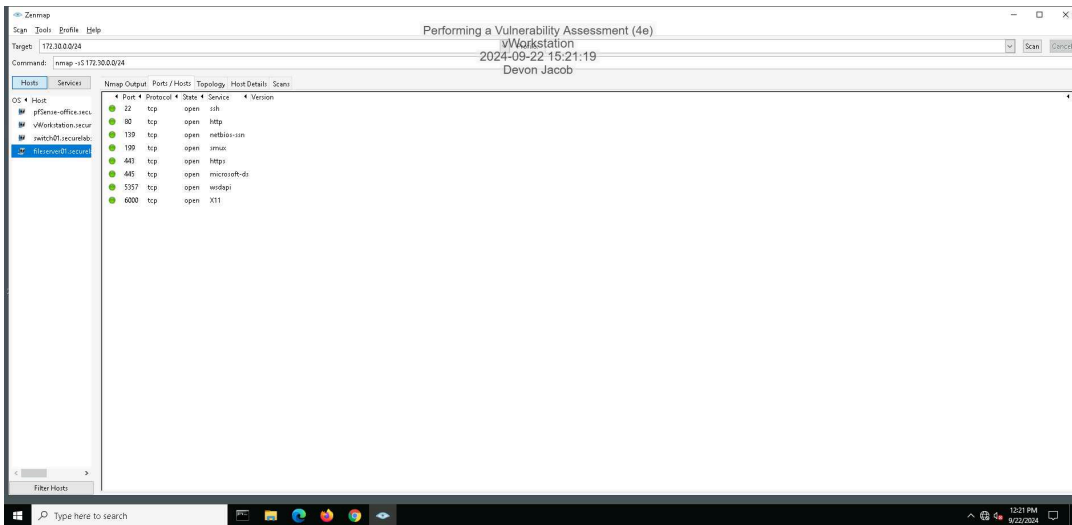
100%

Report Generated: Monday, September 23, 2024 at 7:20 PM

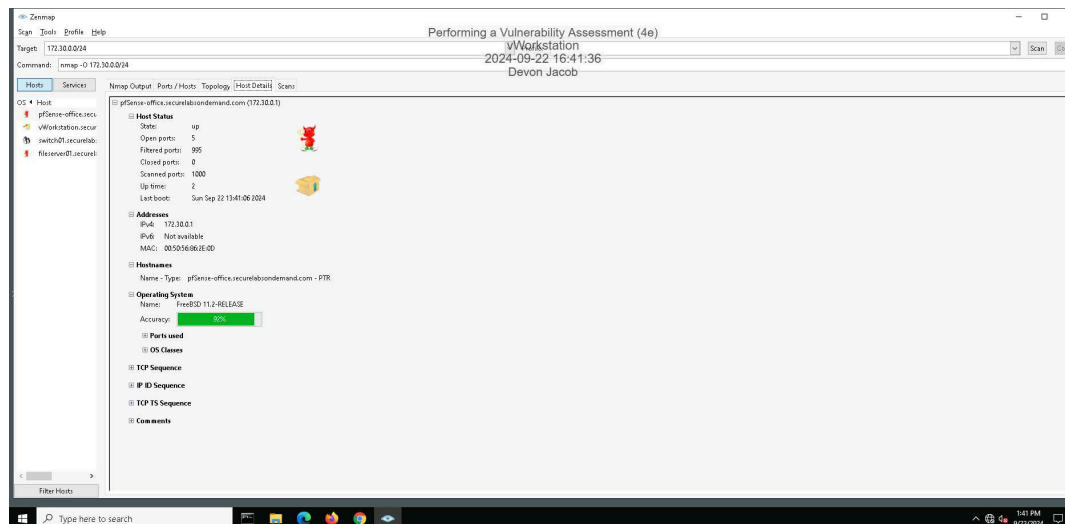
Section 1: Hands-On Demonstration

Part 1: Scan the Network with Zenmap

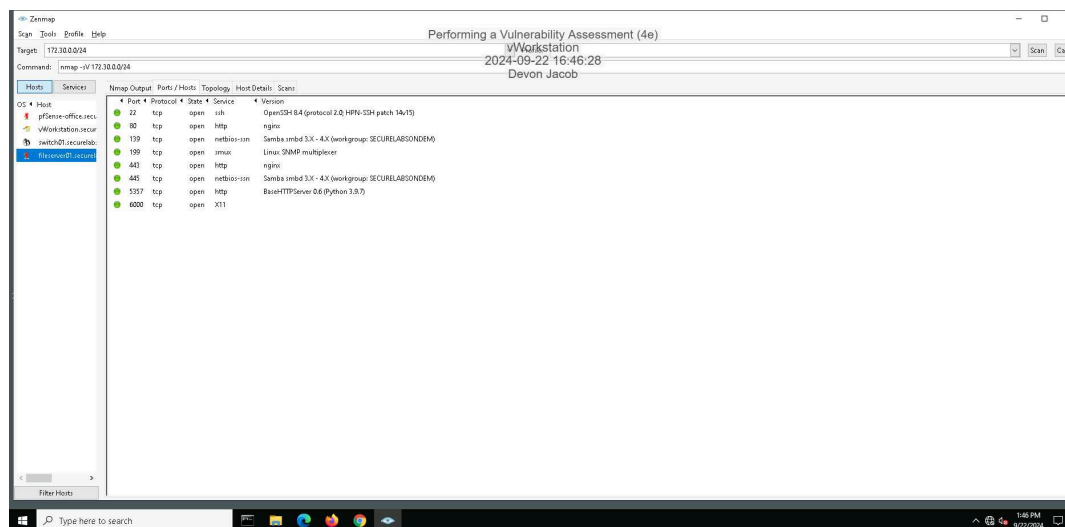
9. Make a screen capture showing the contents of the **Ports/Hosts** tab from the **SYN** scan for **fileserver01.securelabsondemand.com**.



15. Make a screen capture showing the contents of the **Host Details** tab from the OS scan for **fileserv01.securelabsondemand.com**.

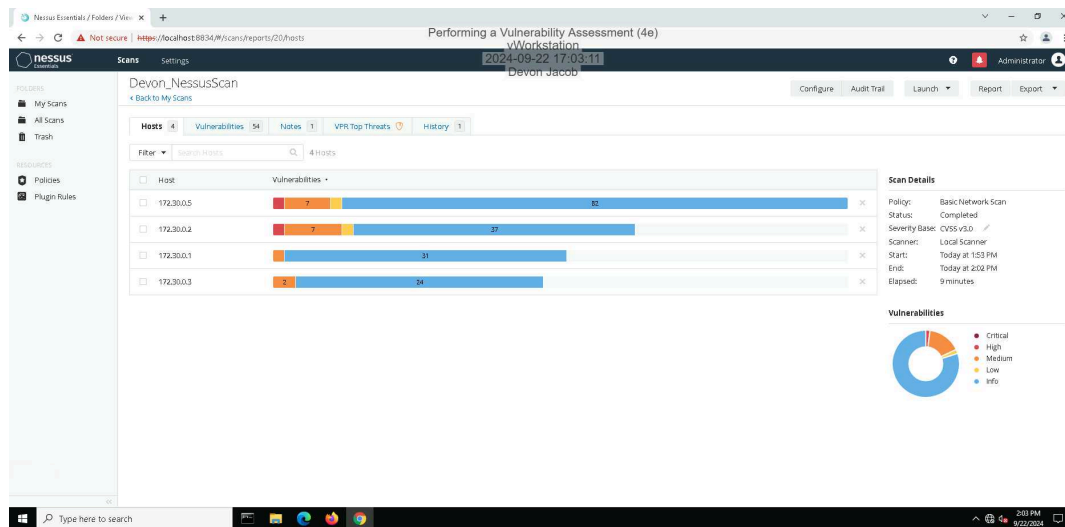


19. Make a screen capture showing the details in the **Ports/Hosts** tab from the Service scan for **fileserv01.securelabsondemand.com**.



Part 2: Conduct a Vulnerability Scan with Nessus

14. Make a screen capture showing the Nessus report summary.



Part 3: Evaluate Your Findings

11. Summarize the vulnerability you selected, including the CVSS risk score, and recommend a mitigation strategy.

In the Nessus scan report, host 172.30.0.5 displayed several medium-severity vulnerabilities. I selected Nessus Plugin ID 76474, which focuses on the SNMP 'GETBULK' Reflection DDoS vulnerability. SNMP (Simple Network Management Protocol) is used for managing and monitoring devices on a network. The SNMP GETBULK request enables the retrieval of large amounts of data from multiple devices at once. However, this feature can be exploited by remote attackers to launch a Reflected DDoS (Distributed Denial of Service) attack, where the attacker floods the victim's network with excessive traffic, leading to overload or service disruptions. The Nessus Plugin ID 76474 has the CVE ID: CVE-2008-4309 which has a base score of 5.0 and listed as medium vulnerability under the CVSS version 2.0. The other versions CVSS 4.0 and CVSS 3.x does not have any score or assessment as yet. To mitigate Distributed DDoS attack, it is important to disable the SNMP service when not in use or in the case that it is in use, then restrict and monitor the access.

Work Cited Haviland, J. (2023, November 28). SNMP GetBulk reflected distributed denial of service attack. Critical Path Security. <https://www.criticalpathsecurity.com/snmp-getbulk-reflected-distributed-denial-of-service-attack/>

SNMP "GETBULK" reflection ddos. Tenable. (n.d.). <https://www.tenable.com/plugins/nessus/76474>

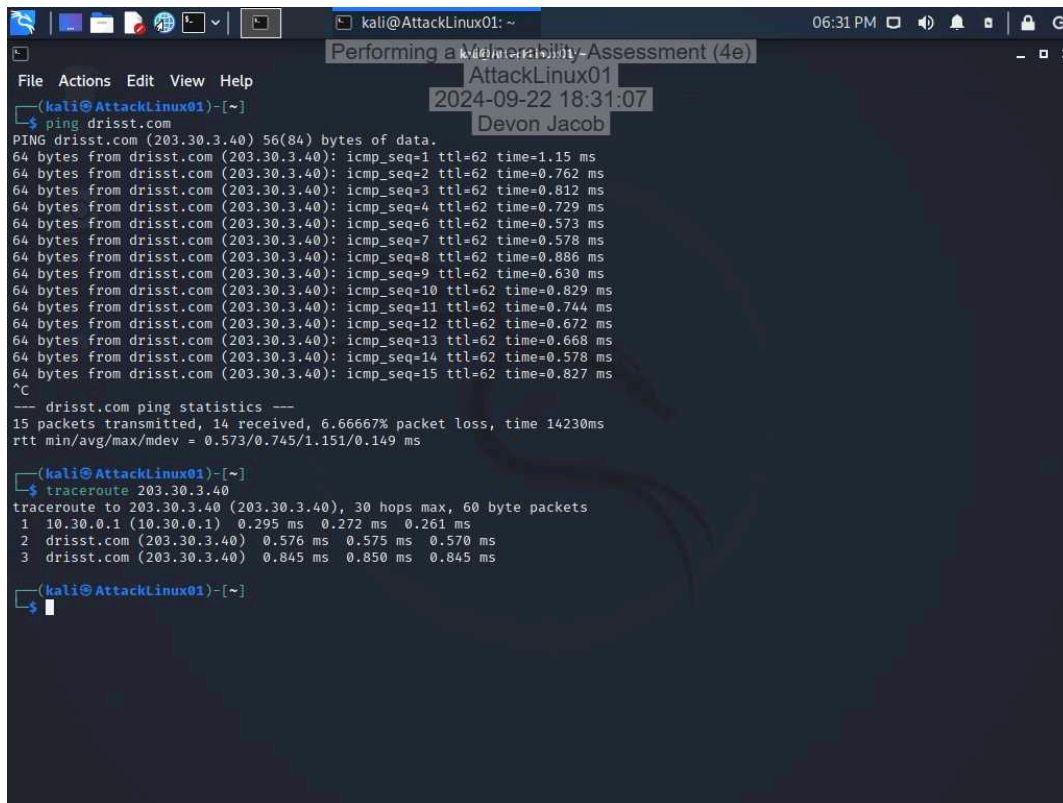
You are viewing this page in an unauthorized frame window. NVD. (n.d.).

<https://nvd.nist.gov/vuln/detail/CVE-2008-4309>

Section 2: Applied Learning

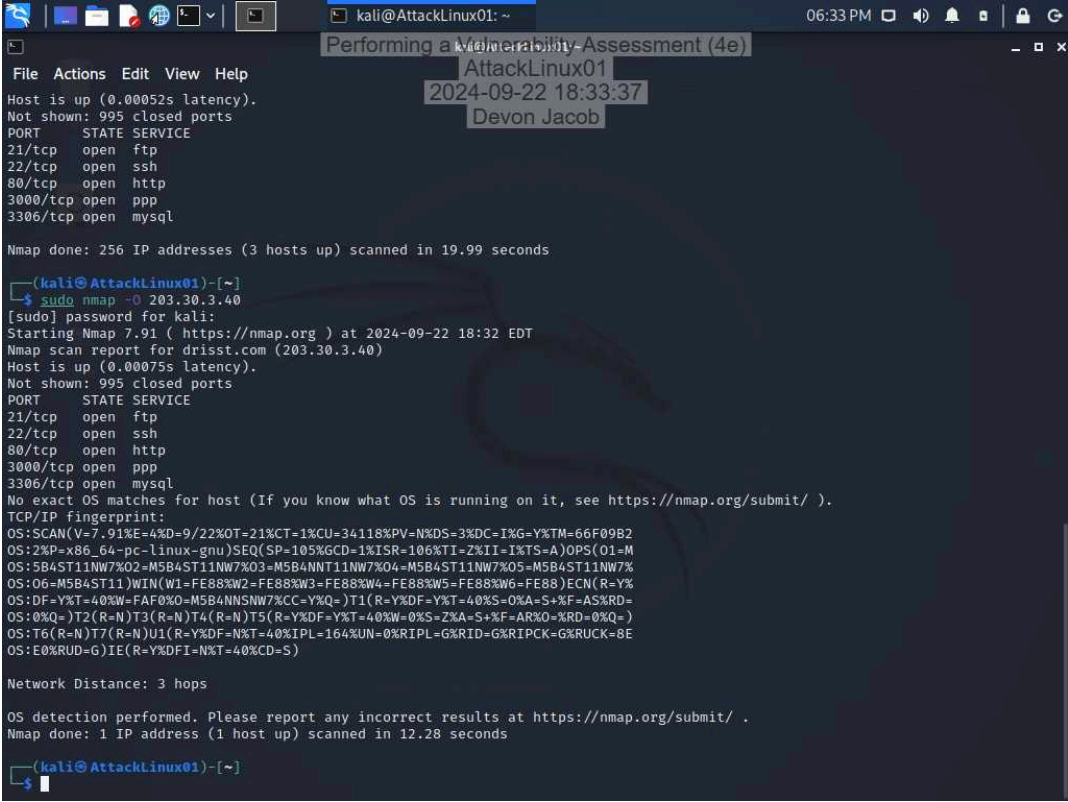
Part 1: Scan the Network with Nmap

6. Make a screen capture showing the results of the traceroute command.



```
(kali@AttackLinux01)~  
$ ping drisst.com  
PING drisst.com (203.30.3.40) 56(84) bytes of data:  
64 bytes from drisst.com (203.30.3.40): icmp_seq=1 ttl=62 time=1.15 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=2 ttl=62 time=0.762 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=3 ttl=62 time=0.812 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=4 ttl=62 time=0.729 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=6 ttl=62 time=0.573 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=7 ttl=62 time=0.578 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=8 ttl=62 time=0.886 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=9 ttl=62 time=0.630 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=10 ttl=62 time=0.829 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=11 ttl=62 time=0.744 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=12 ttl=62 time=0.672 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=13 ttl=62 time=0.668 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=14 ttl=62 time=0.578 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=15 ttl=62 time=0.827 ms  
^C  
--- drisst.com ping statistics ---  
15 packets transmitted, 14 received, 6.6667% packet loss, time 14230ms  
rtt min/avg/max/mdev = 0.573/0.745/1.151/0.149 ms  
  
(kali@AttackLinux01)~  
$ traceroute 203.30.3.40  
traceroute to 203.30.3.40 (203.30.3.40), 30 hops max, 60 byte packets  
 1  10.30.0.1 (10.30.0.1)  0.295 ms  0.272 ms  0.261 ms  
 2  drisst.com (203.30.3.40)  0.576 ms  0.575 ms  0.570 ms  
 3  drisst.com (203.30.3.40)  0.845 ms  0.850 ms  0.845 ms  
  
(kali@AttackLinux01)~  
$
```

10. Make a screen capture showing the results of the Nmap scan with OS detection activated.



```
File Actions Edit View Help
Host is up (0.00052s latency).
Not shown: 995 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
3000/tcp  open  ppp
3306/tcp  open  mysql

Nmap done: 256 IP addresses (3 hosts up) scanned in 19.99 seconds

(kali@AttackLinux01)-[~]
$ sudo nmap -O 203.30.3.40
[sudo] password for kali:
Starting Nmap 7.91 ( https://nmap.org ) at 2024-09-22 18:32 EDT
Nmap scan report for drisst.com (203.30.3.40)
Host is up (0.00075s latency).
Not shown: 995 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
3000/tcp  open  ppp
3306/tcp  open  mysql
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.91%E=4%D=9/22%OT=21%CT=1%CU=34118%PV=N%DS=3%DC=I%G=Y%TM=66F09B2
OS:2%P=x86_64-pc-linux-gnu)SEQ(SP=105%GCD=1%ISR=106%TI=Z%II=I%TS=A)OPS(O1=M
OS:5B4ST11NW7%O2=M5B4ST11NW7%O3=M5B4NNT11NW7%O4=M5B4ST11NW7%O5=M5B4ST11NW7%
OS:O6=M5B4ST11)WIN(W1=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%
OS:DF=Y%T=40%W=FAF0%O=M5B4NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=
OS:0%Q=)T2(R=N)T3(R=N)T4(R=N)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=0%RD=0%Q=)
OS:T6(R=N)T7(R=N)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=8E
OS:E0%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

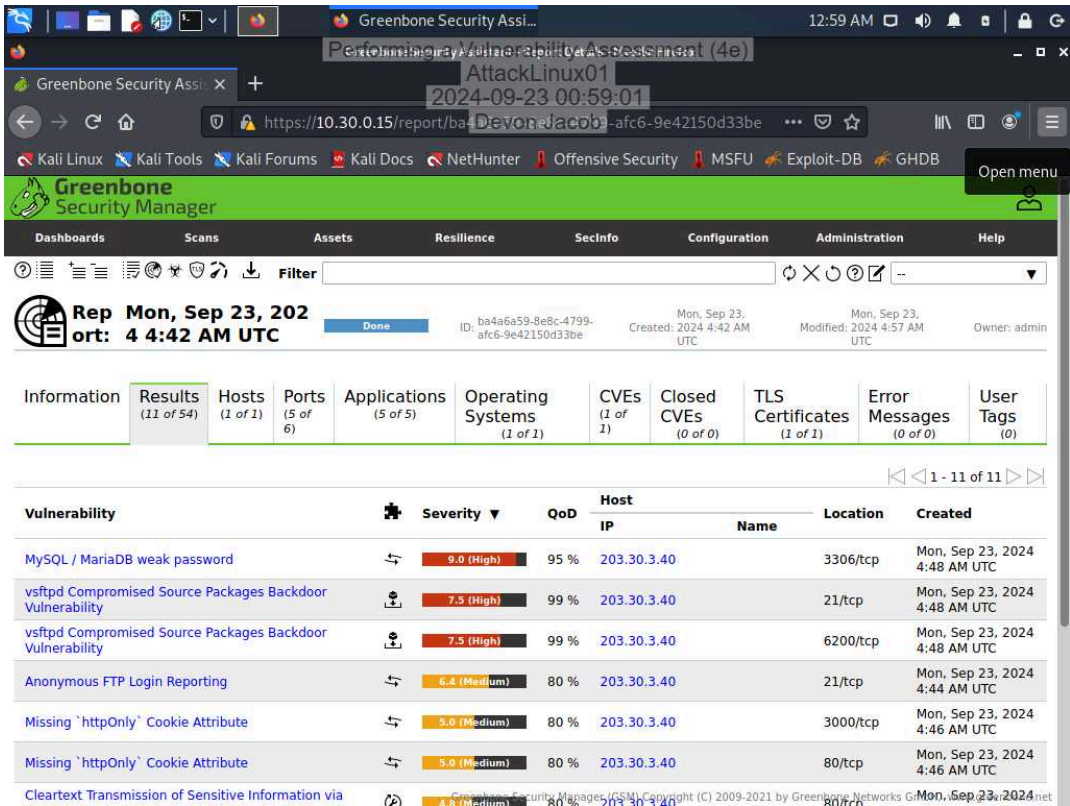
Network Distance: 3 hops

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.28 seconds

(kali@AttackLinux01)-[~]
$
```

Part 2: Conduct a Vulnerability Scan with OpenVAS

13. Make a screen capture showing the detailed OpenVAS scan results.



Part 3: Prepare a Penetration Test Report

Target

Insert the target here.

drisst.com

Completed by

Insert your name here.

Devon Jacob

On

Insert current date here.

9/23/2024

Purpose

Identify the purpose of the penetration test.

The purpose of this penetration test is to identify vulnerabilities present in the drisst.com web server.

Scope

Identify the scope of the penetration test.

The scope of the penetration test is to conduct a vulnerability scan using OpenVAS to identify high severity vulnerabilities on the drisst.com web server.

Summary of Findings

Identify and summarize each of the three high-severity vulnerabilities identified during your penetration test. For each vulnerability, identify the severity, describe the issue, and recommend a remediation.

During the penetration test done on drisst.com web server using OpenVAS, three high severity vulnerabilities that were found are: **Vulnerability One:** MySQL/MariaDB weak password. **Severity:** 9.0 (High) **Description:** It was possible to login into the remote MySQL as root using weak credentials. This vulnerability presents high risk as it allows unauthorized users to access the database which can therefore compromise the integrity of the system. **Recommended Remediation:** Immediately update the password and ensure that all root users utilize strong, complex, and secure passwords. Additionally, implement multi-factor authentication (MFA) for all users to require an additional form of verification before granting access during login.

Vulnerability Two: vsftpd Compromised Source Package Backdoor Vulnerability (21/TCP) **Severity:** 7.5 (High) **Description:** The VSFTPD (Very Secure File Transfer Protocol Daemon) software package is susceptible to a backdoor access through port 21/TCP. This could enable an attacker to gain unauthorized root access to the system. Once access is obtained, the attacker can execute arbitrary commands to perform a wide range of malicious attacks. **Recommended Remediation:** Uninstall the compromised version and replace it with a verified version, ensuring that the software is kept up to date at all times. **Vulnerability Three:** vsftpd Compromised Source Package Backdoor Vulnerability (6200/TCP)

Severity: 7.5 (High) **Description:** Attackers can exploit vulnerabilities in VSFTPD to gain backdoor access through TCP port 6200. This port serves as an entry point that can allow unauthorized users to bypass security measures. **Recommended Remediation:** Configure firewall rules to restrict access to TCP port 6200, allowing only trusted IP addresses to connect.

Based on research conducted through the CVE database about the high severity vulnerabilities found, it was discovered that the vulnerability MySQL/MariaDB Weak Password was (CVE-2012-2122) and the vulnerability vsftpd Compromised Source Package Backdoor Vulnerability was (CVE-2011-2523).

Work Cited CVE website. (n.d.-a). <https://www.cve.org/CVERecord?id=CVE-2011-2523> CVE website. (n.d.-b). <https://www.cve.org/CVERecord?id=CVE-2012-2122>

Conclusion

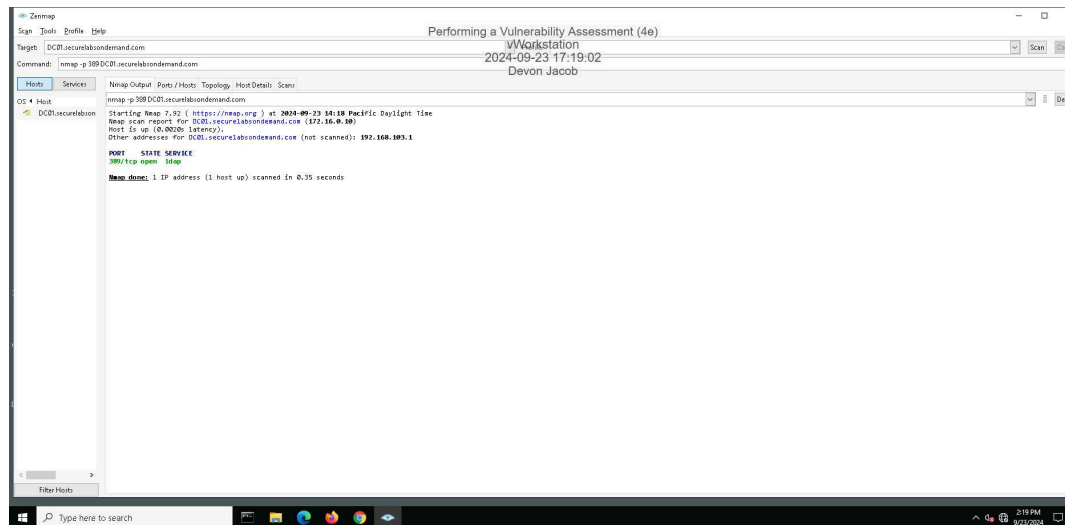
Identify your key findings.

The key findings from this penetration test indicate that the drisst.com web server has several critical vulnerabilities that could be exploited by attackers. The three high severity vulnerabilities found were *MySQL/MariaDB weak password* with a 9.0 severity, *vsftpd Compromised Source Package Backdoor Vulnerability (21/TCP)* with a severity of 7.5 and *vsftpd Compromised Source Package Backdoor Vulnerability (6200/TCP)* with a severity of 7.5 also. Vulnerability two and three are similar except the backdoor vulnerability differs in the port they can exploit. It is important for organizations to take immediate recommended actions such as changing weak passwords to more complex and secure passwords, also enable multi-factor (MFA) authentication to prevent unauthorized access. In addition, the organizations should also make sure vsftpd software are always kept updated.

Section 3: Challenge and Analysis

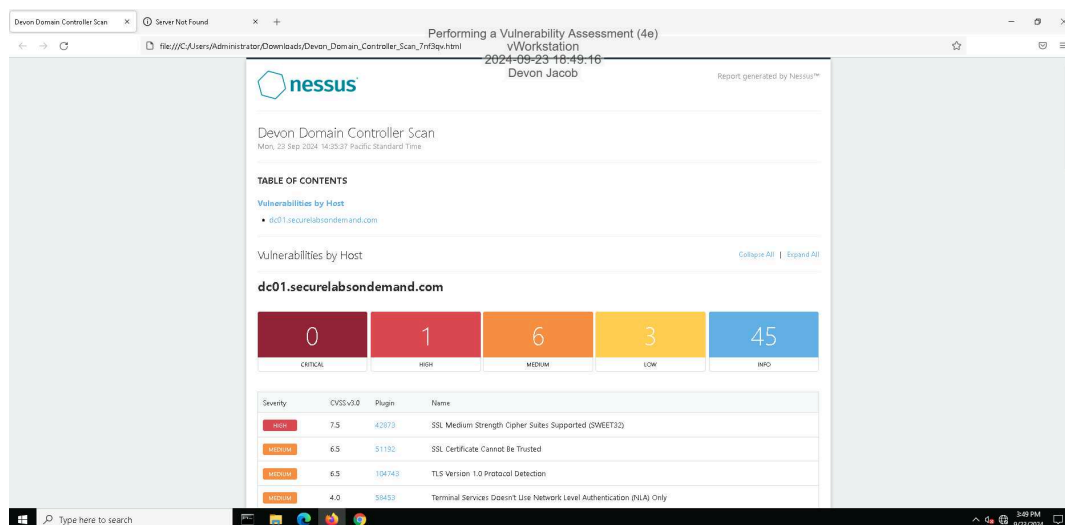
Part 1: Scan the Domain Controller with Nmap

Make screen capture showing the results of your targeted port scan on the domain controller.



Part 2: Scan the Domain Controller with Nessus

Make a screen capture showing the Nessus report summary for the domain controller.



Part 3: Prepare a Penetration Test Report

Performing a Vulnerability Assessment (4e)

Fundamentals of Information Systems Security, Fourth Edition - Lab 02

Target

Insert the target here.

dc01.securelabsondemand.com

Completed by

Insert your name here.

Devon Jacob

On

Insert current date here.

09/23/2024

Purpose

Identify the purpose of the penetration test.

The purpose of this penetration test is to identify high vulnerability on the domain controller, dc01.securelabsondemand.com

Scope

Identify the scope of the penetration test.

The scope of this penetration test is to use Nessus scan report to identify high vulnerability on the domain controller, dco1.securelabsondemand.com

Summary of Findings

Identify and summarize each vulnerability identified during your penetration test. For each vulnerability, identify the severity, describe the issue, and recommend a remediation.

During the penetration test done on the domain controller *dc01.securelabsondemand.com* using Nessus. The scan report identified one high severity vulnerability. **Vulnerability:** SSL Medium Strength Cipher Suites Supported (SWEET32) **Severity:** 7.5 (High) **Description:** The SWEET32 vulnerability allows remote attackers to easily retrieve cleartext data through a birthday attack on an extended encrypted session when OpenVPN utilizes a 64-bit block chipper. Based on the CVE research conducted it revealed that SWEET32 vulnerability is CVE-2016-6329 in the CVE database. **Recommended Remediation:** Always ensure that users are using the updated version of OpenVPN also, update the OpenVPN configuration to disable 64-bit ciphers. **Work Cited** CVE website. (n.d.). <https://www.cve.org/CVERecord?id=CVE-2016-6329>

Conclusion

Identify your key findings.

The penetration test conducted using Nessus on *dc01.securelabsondemand.com* identified SWEET32 vulnerability (CVE-2016-6329) as high severity issue rated at 7.5. This vulnerability possesses a significant risk of data exposure since it allows remote attackers to exploit 64-bit block cipher which allows cleartext data retrieval. To remediate this vulnerability, it is important to use updated OpenVPN and disabling weak cipher.